INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

GRC103

RISK ASSESSMENT AND MANAGEMENT TECHNIQUES

MODULE 3 | RISK TREATMENT STRATEGIES

RANSOMWARE RISK TREATMENT CASE LAB

Risk Treatment Decision and Executive Recommendation

SUBMISSION DETAIL	INFORMATION
Student	Kefilwe Matake
Registration Number	C11_26_CGRCE_17575
Role	GRC Analyst
Assessment	Module 3 Ransomware Risk Treatment Case Lab
Organisation	Northbridge Community Health (Fictional)
Submission Package	Decision Report + Editable Risk Treatment Workbook

Executive Decision Summary

Purpose. Advise Northbridge Community Health on a $100,000 first-year ransomware risk-treatment budget. Detailed calculations, full risk register, budget formulas, insurance formulas, and the initial/revised decision log are maintained in the accompanying Excel workbook.

Spreadsheet containing the risk register, budget and insurance calculations

https://docs.google.com/spreadsheets/d/15CkVSNh_C4VmsD5dtOUFDVaFaF44PSmL/edit?usp=sharing&ouid=100737579588176637722&rtpof=true&sd=true

Evidence basis

HSE fact 1: The 2021 HSE cyber-attack followed a phishing email attachment sent in March; ransomware was triggered in May.

HSE fact 2: Files were encrypted and information was copied; HSE states that no ransom was paid. These facts are separate from the fictional Northbridge scenario assumptions.

Priority risk position

Risk	Why it matters	Initial	Owner
Service disruption	Untested recovery threatens essential bookings and continuity.	20 Critical	COO / IT Recovery
Sensitive-data loss	Phishing/access weakness may expose sensitive patient and operational data.	15 High	CISO / Data Protection
Supplier exposure	Unused supplier workflow creates avoidable external exposure.	12 High	App Owner / Procurement
Delayed detection	No escalation owner can extend attacker dwell time and impact.	16 High	CISO / SecOps

Initial treatment decision

Select A + B + C + D for $95,000, leaving $5,000. This combines avoidance (retire the unused supplier workflow) with direct mitigation of identity/access, recovery and detection weaknesses. Option F is deferred as a longer-term architecture improvement; Option G is initially rejected because direct controls reduce the underlying risk more effectively.

Treatment logic

- A - Retire the unused supplier workflow: low-cost avoidance of an unnecessary attack path.
- B - MFA and account access review: reduces account misuse and supports sensitive-data risk treatment.
- C - Protected backups, restoration tests and recovery plan: primary treatment for the Critical continuity risk.
- D - Managed detection and incident escalation: gives phishing and security alerts a named operational owner and escalation path.

Scenario Change and Revised Decision

Change event. The restoration test fails, paper bookings can continue for only four hours, and Option B increases to $35,000. Recovery therefore becomes the immediate gating issue, while the same $100,000 budget must be maintained.

Revised portfolio

Select A + C + D + E + G for exactly $100,000. This protects continuity and detection, adds targeted awareness/reporting, keeps supplier-risk avoidance, and uses insurance only as partial financial transfer. MFA/access review (B) is deferred under a time-limited, board-escalated acceptance; network segmentation (F) remains a longer-term improvement.

Insurance interpretation

Covered loss	Insurer payment	Retained loss	Management meaning
$180,000	$155,000	$25,000	With the $20,000 premium, first-year outlay is $45,000.
$400,000	$250,000 cap	$150,000	With the premium, first-year outlay is $170,000. If excluded, Northbridge bears the full loss plus any premium already paid.

Residual-risk position

- Service disruption remains Critical until a controlled restoration test succeeds. Critical risk cannot be accepted under the classroom scale.
- Sensitive-data loss remains High because MFA/access review is deferred. Detection, awareness and insurance reduce exposure but do not remove the underlying accountability.
- Supplier exposure can reduce to Low only after the unused workflow, related credentials and connectivity are confirmed disabled.
- Delayed detection can reduce to Medium if alert routing, named ownership and end-to-end escalation are tested successfully.

30-day priorities

Action	Owner	Cost	Effectiveness evidence
Retire supplier workflow	App Owner / Procurement	$5,000	Disable workflow, credentials and connectivity; retain owner sign-off.
Repair recovery and retest	IT Recovery Lead / COO	$30,000	Successful controlled restore proves continuity within the four-hour fallback window or approved alternative.

Action	Owner	Cost	Effectiveness evidence
Activate managed detection	CISO / SecOps	$35,000	Test alert creates a case, reaches the named owner and is triaged to target.
Awareness + reporting process	CISO / HR	$10,000	Training complete; test phishing report creates traceable escalation.
Illustrative insurance	CFO / Risk	$20,000	Validate deductible, cap, exclusions and claims process in a tabletop exercise.

Board Memo

To: Board Risk Committee

From: Lead GRC Analyst

Subject: Approval of Revised Ransomware Risk Treatment Portfolio

Northbridge Community Health requires approval of a revised $100,000 first-year ransomware treatment portfolio. The failed restoration test materially increases our service-continuity concern because paper bookings can sustain operations for only four hours. Under the classroom risk scale, service disruption remains Critical and cannot be accepted until recovery capability is implemented and a controlled restoration test succeeds.

I recommend funding Option A ($5,000) to remove the unused supplier workflow, Option C ($30,000) for protected backups and tested recovery, Option D ($35,000) for managed detection and named incident escalation, Option E ($10,000) for targeted awareness and phishing-reporting, and Option G ($20,000) for limited financial transfer. The portfolio uses the full $100,000 budget.

MFA and access review (Option B) is deferred after its cost rises to $35,000. This is not a permanent acceptance. The CISO owns the residual identity/access risk until 12 December 2026, with immediate review if a phishing-related credential compromise, privileged-account event, material access-review exception, or earlier funding opportunity occurs. Network segmentation (Option F) remains a longer-term treatment.

Approval is requested for the revised portfolio, the time-limited MFA deferral, and continued Board oversight of the Critical continuity risk and remaining High data-loss risk. Detailed scoring, budget and insurance calculations are retained in the accompanying editable workbook.

Submission note

Detailed calculations are intentionally not duplicated in this narrative report. The accompanying workbook contains the full risk register, initial and revised budget decisions, insurance formulas, residual-risk scoring, 30-day action plan, and source/assumption register.

Official source

Health Service Executive (HSE), “Cyber-attack and HSE response.”
https://www2.hse.ie/services/cyber-attack/what-happened/

Real HSE incident facts are used only for context. Northbridge, its $100,000 budget, treatment prices and scenario change are fictional classroom assumptions supplied in the assignment brief.